LOGION 모의해킹 · 침해대응 결과보고서

가상 물류기업 LOGION 대상 Red/Blue 팀 프로젝트

DRAFT · 초안

프로젝트명	LOGION 모의해킹 · 침해대응 (Operation Ghost Delivery)
소속 / 과정	[교육기관 · 과정명 입력]
수행 기간	[2026.10 ~ 2026.11, 약 2주 — 실제 기간 입력]
팀 구성	RED 2명 / BLUE 2명
작성자 / 담당	[작성자] — 네트워크 아키텍처 설계, WebAPI · WAF 구축
작성일	2026-11-06
저장소	https://github.com/nb02079-ai/PenetrationTesting

1. 개요 (Executive Summary)

가상 물류기업 **LOGION**의 웹 서비스·내부망을 대상으로, 외부 공격자 관점(Red)의 침투와 방어·탐지 관점(Blue)의 대응을 동시에 수행하였다. VirtualBox 기반으로 DMZ·내부서버망·사내업무망·보안관제망 4개 대역을 pfSense 이중 방화벽으로 분리한 격리 랩을 구축하고, 세 가지 공격 시나리오(CASE 1~3)에 대해 **공격 → 탐지 → 대응 → 재시험**의 전 과정을 검증하였다.

핵심 결과로, 경계 방어(WAF)가 **탐지하는 공격(파일 업로드)**과 **탐지하지 못하는 공격(권한 오류·계정 관리)**이 명확히 구분됨을 확인하였다. 이는 경계 방어만으로는 불충분하며, 애플리케이션 로직·계정 수명주기 관리·SIEM이 함께 작동하는 다계층 방어가 필요함을 실증한다.

2. 대상 및 범위

항목	내용
대상	가상기업 LOGION 물류·배송 포털 및 내부 인프라 (실제 기업 아님)
범위	외부→DMZ→내부 침투 경로, 웹 애플리케이션 취약점, 잔존 계정, 탐지·대응 체계
방식	교육용 **격리 랩** 전용 · 더미 데이터 · 무해한 마커 파일(실제 악성코드 미사용)
근거	제공된 SOW(Statement of Work) 기반

3. 환경 구성

GNS3 대신 **VirtualBox 단일 가상화**를 사용하였다(호스트 자원 16GB 제약). 각 대역은 VirtualBox 내부 네트워크로 격리하고, 세그먼트 간 통제는 pfSense 2대(경계·내부)가 담당한다. 관제망(SOC)만 2번째 PC의 Wazuh로 브리지 연결하여 자원을 분산하였다.

공격 경로: Kali(10.10.99.10) → pfSense#1 → WAF(10.10.10.5) → WebAPI(10.10.10.20) → pfSense#2 → MariaDB(10.10.20.10)

대역	CIDR	주요 자산
외부(공격자)	10.10.99.0/24	Kali
DMZ	10.10.10.0/24	WAF, WebAPI
내부서버망	10.10.20.0/24	MariaDB, Bastion
사내업무망	10.10.30.0/24	협력업체 PC
보안관제망(OOB)	10.10.40.0/24	Wazuh (SIEM), Suricata

구성·연결 상세: `docs/토폴로지_연결방식.md` · 사전 점검 증거: `LOGION_Evidence/00_Preparation/` (라우팅·통신검증·초기값)

4. 공격 시나리오 결과

CASE 1 — 배송지 무단 변경 (BOLA)

기법	OWASP API1:2023 BOLA / MITRE **T1565.001**
취약점	배송 변경 API가 소유권을 검증하지 않아, 다른 사용자의 `shipment_id` 만 지정하면 남의 배송지 변경 가능
공격	고객 A(ua) 인증 상태에서 고객 B(ub)의 배송지를 임의 변경 → **성공** (HTTP 302 s=ok). **[C01-02, C01-03]**
탐지	**WAF/Wazuh 미탐지** — CRS에 해당 시그니처 없음(프로토콜 경고 920350만). 실제 증거는 DB 감사(`shipment_address_history`: 변경자≠소유자)에만 존재. **[C01-04, C01-05]**
대응	서버 측 소유권 검증 추가(세션 사용자의 주문에 속한 배송만 변경 허용). **[C01-06]**
재시험	동일 공격 → **차단**(s=err "본인 배송이 아니거나…", `api_audit_logs` 403 DENIED, DB 불변). **[C01-07, C01-08]**

CASE 2 — 물류문서 업로드 검증 누락

기법	MITRE **T1505.003** (Web Shell)
취약점	업로드 시 확장자·내용 검증 없이 원본 파일명 그대로 웹 접근 경로에 저장 → 업로드 파일 실행 가능
공격	잔존 STAFF 계정으로 무해한 마커 `.php` 업로드 후 실행 → **성공**(마커 출력 확인). **[C02-02, C02-03]**
탐지	**WAF 탐지** — ModSecurity CRS **933110**(PHP Script File Upload) → Wazuh 룰 **100304**. **[C02-05]**
대응	확장자 허용목록 + 웹루트 밖(비실행 경로) 랜덤 파일명 저장. (선택: WAF 차단 모드 전환) **[C02-06]**
재시험	`.php` → **거부**(REJECTED) + 접근 404(미저장·실행 불가). **[C02-07, C02-08]**

CASE 3 — 잔존 외주 관리계정 침투

기법	MITRE **T1078**(Valid Accounts) + **T1021**(Remote Services)
취약점	폐기됐어야 할 협력업체 계정(partner01)이 ACTIVE로 잔존 → 유효 계정으로 점프호스트(Bastion) 경유 내부 침투
공격	사내 협력PC에서 잔존 계정으로 Bastion SSH 침투 → 내부 고객정보 열람 → **성공**. **[C03-01, C03-03]**
탐지	**Bastion auditd → Wazuh**(로그인·명령 기록) + **분리 검증**(사내PC→DB 직접 접근은 차단, Bastion:22만 허용). **[C03-02, C03-04]**
대응	잔존 계정 폐기 — 웹 계정 DISABLED + Bastion OS 계정 잠금. **[C03-05]**
재시험	SSH·포털 재접속 모두 **거부**(인증 실패 로그 확인). **[C03-06, C03-07]**

5. 종합 분석 (Purple)

세 CASE를 탐지 주체 관점에서 대조하면, 경계 방어(WAF)의 탐지 범위가 공격 유형에 따라 극명하게 갈린다.

CASE	공격 성공	WAF 탐지	SIEM 탐지 주체	근본 원인
1 BOLA	O	X (공백)	DB 감사(앱 계층)	인가 로직 결함
2 업로드	O	O (933/100304)	WAF → Wazuh	입력 검증 누락
3 잔존계정	O	X	auditd(호스트)	계정 수명주기 관리 실패

> **핵심:** WAF는 **알려진 페이로드 패턴(SQLi·파일 업로드)**은 탐지하나, **인가 오류(BOLA)·계정 관리 결함**은 구조적으로 탐지하지 못한다. 또한 애플리케이션 계층 차단(302 리다이렉트)은 네트워크/WAF SIEM에 신호를 남기지 않아, 조치 전후를 네트워크 로그만으로는 구별할 수 없었다(DB·auditd 로그로만 확인).

6. 대응 권고

- **애플리케이션 계층 탐지 강화** — 인가 위반·API 남용은 WAF 밖이므로, 앱 감사 로그(`api_audit_logs` 등)를 SIEM으로 포워딩하고 "행위자≠소유자" 류 상관 룰을 추가한다.
- **계정 수명주기 관리** — 외주·협력 계정의 만료/폐기 프로세스를 정례화하고, 잔존 계정 탐지(미사용 계정·권한)를 주기 점검한다.
- **입력 검증 표준화** — 업로드는 허용목록 + 비실행 경로 저장을 기본으로 하고, WAF는 탐지→차단 모드로 단계 전환한다.
- **최소 권한 · 분리** — 점프호스트 강제(직접 DB 접근 차단)는 유효했다. DB 공유 크리덴셜을 계정별·용도별로 분리한다.

7. 결론

LOGION 랩에서 세 가지 공격 경로가 모두 성공적으로 재현되고, 각기 다른 계층의 대응으로 차단됨을 확인하였다. 특히 "WAF가 잡는 공격 vs 못 잡는 공격"의 대조를 통해, 보안은 단일 경계 장비가 아니라 **애플리케이션·호스트·계정 관리·SIEM이 결합된 다계층 방어**로 설계되어야 함을 실증하였다. 모든 공격·탐지·대응 과정은 저장소의 `LOGION_Evidence/`에 캡처 증거(C01~C03)로 보존되어 있다.

> **초안 보완 필요:** [소속·기간·작성자] 입력, 각 CASE에 실제 캡처 이미지 삽입, 수치(탐지 건수·소요 시간) 보강, 팀원별 역할 분담 상세.